

Cloud Security Checklist

A 40-point checklist covering identity, network, storage, and logging misconfigurations across AWS, Azure, and GCP. Use it as a self-assessment before an external review, or as a baseline for new environments.

Identity & Access (10)

- ☐ MFA is enforced for all users with console/portal access (AWS IAM, Microsoft Entra ID, GCP IAM).
- ☐ Root / Global Admin / Organization Owner accounts are not used for daily operations.
- ☐ No long-lived access keys exist for human users; keys are scoped to service accounts only.
- ☐ IAM policies follow least privilege — no wildcard (*:*) permissions on production resources.
- ☐ Privileged roles require just-in-time elevation, not standing access.
- ☐ Federated SSO is enforced for console access instead of local IAM users where possible.
- ☐ Service accounts and workload identities are inventoried and reviewed quarterly.
- ☐ Cross-account / cross-subscription / cross-project trust relationships are documented and reviewed.
- ☐ Unused IAM users, roles, and access keys older than 90 days are deactivated or removed.
- ☐ Access reviews are performed at least quarterly for all privileged roles.

Network (10)

- ☐ No security groups / NSGs / firewall rules allow unrestricted inbound access (0.0.0.0/0) on management ports (22, 3389, etc.).
- ☐ Production workloads are network-segmented from development and test environments.
- ☐ A default-deny posture is enforced for inbound traffic; only required ports are explicitly opened.
- ☐ VPC/VNet peering and transit gateway routes are documented and reviewed on a defined cadence.
- ☐ Internet-facing web services sit behind a WAF or equivalent layer.
- ☐ DDoS protection is enabled for internet-facing endpoints.
- ☐ Private endpoints / PrivateLink are used for sensitive managed services instead of public endpoints.
- ☐ Flow logs are enabled on all VPCs/VNets for traffic visibility.
- ☐ DNS resolution and zones are reviewed for unauthorized or stale records.
- ☐ Bastion/jump host access requires MFA and is fully logged.

Storage & Data (10)

- ☐ No storage buckets, containers, or blobs are publicly readable or writable unintentionally.
- ☐ Encryption at rest is enabled by default for all storage services.
- ☐ Encryption in transit (TLS) is enforced for all data access endpoints.
- ☐ Customer-managed encryption keys are used for the most sensitive data stores.
- ☐ Versioning and soft-delete/recovery are enabled on critical storage resources.
- ☐ Backup jobs are automated, monitored, and validated through periodic restore drills.
- ☐ Database instances are not directly internet-accessible.
- ☐ Snapshots and backups are not publicly shared or overly permissive.
- ☐ Data classification tags are applied to identify sensitive data stores.
- ☐ Data retention and deletion policies are defined and actively enforced.

Logging & Monitoring (10)

- ☐ Centralized, immutable audit logging is enabled (CloudTrail, Azure Activity Log, GCP Audit Logs).
- ☐ Logs are retained for a minimum of 1 year (longer where regulated data applies).
- ☐ Alerts are configured for high-risk events (root login, IAM policy changes, security group changes).
- ☐ A cloud security posture management (CSPM) tool is deployed and actively reviewed.
- ☐ GuardDuty / Microsoft Defender for Cloud / Security Command Center (or equivalent) is enabled everywhere.
- ☐ Logs are shipped to a central SIEM or log analytics workspace outside the source account.
- ☐ Billing / cost anomaly alerts are configured to catch cryptomining or resource abuse.
- ☐ A documented incident response plan exists specific to cloud-hosted workloads.
- ☐ Regular (at least annual) third-party or internal cloud security assessments are performed.
- ☐ Findings from CSPM/scanning tools are tracked to remediation with defined SLAs.